

Case Study: **An Anonymous and Secure Biometric-Based Enterprise DRM System for Mobile Environment**

Dheerendra Mishra, Ashok Kumar Das, and Sourav Mukhopadhyay. "An anonymous and secure biometric-based enterprise digital rights management system for mobile environment," in **Security and Communication Networks (Wiley)**, Vol. 8, No. 18, pp. 3383-3404, 2015, DOI: 10.1002/sec.1266.

Introduction

- ▶ Digital Rights Management (DRM) protects digital content.
- ▶ Mobile environments introduce new security challenges.
- ▶ Biometrics provides strong authentication.
- ▶ Proposed scheme:
 - ▶ Ensures anonymity
 - ▶ Uses fuzzy extractor
 - ▶ Supports secure key distribution

Biometric Verification

- ▶ Pattern recognition system
- ▶ Extracts features from biometric data
- ▶ Compares with stored templates

Advantages:

- ▶ Cannot be forgotten
- ▶ Hard to forge
- ▶ Difficult to share
- ▶ High security

Fuzzy Extractor

Let $M = \{0, 1\}^v$ be a metric space.

Definition

A fuzzy extractor (M, l, t) extracts a random string σ_i from biometric input.

Algorithms:

- ▶ $\text{Gen}(B_i) \rightarrow (\sigma_i, \tau_i)$
- ▶ $\text{Rep}(B'_i, \tau_i) \rightarrow \sigma_i$

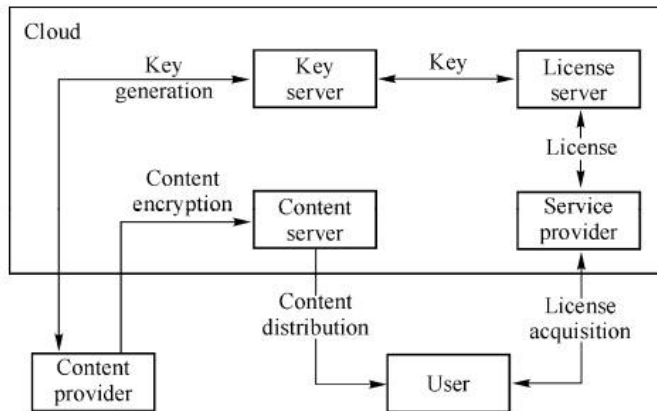
Condition:

$$d(B_i, B'_i) \leq t$$

Cloud-Based DRM Framework

- ▶ Entities:
 - ▶ Mobile User (MU)
 - ▶ Content Server (CS)
 - ▶ License Server (LS)
 - ▶ Package Server (PS)
- ▶ Content encrypted and distributed via servers
- ▶ License required for access

Cloud-based DRM Framework



Phases of Proposed Scheme

- ▶ Registration Phase
- ▶ Package Phase
- ▶ Content Key Acquisition Phase
- ▶ Password & Biometric Update Phase

Notations

TABLE I
NOTATIONS USED IN THIS PAPER

Notation	Description
MU	Mobile user
CS	Content server
LS	License server
AA	Authorization authority
PS	Package server
ID_{MU}	Identity of MU
ID_{DC}	Identity of digital content DC
$KEY_{ID_{DC}}$	Randomly generated symmetric key by PS
AID	Anonymous identity chosen by MU
Req	Registration request message of MU in Chang et al.'s scheme [9]
PW_{MU}	Unique password of MU
T_{MU}	Timestamp generated by MU
T_{AA}	Timestamp generated by AA
T_{LS}	Timestamp generated by LS
X	Master key of LS in our scheme
IMEI	Unique international mobile equipment identification number assigned to each mobile terminal
$Sym.Enc_K(\cdot)/$	Symmetric encryption/
$Sym.Dec_K(\cdot)$	decryption using key K
$H(\cdot)$ & $F(\cdot)$	One-way hash functions
DRM-AP	DRM-enabled application
$\oplus$	Bitwise XOR operation
$ $	String concatenation operation

Registration Phase (User Side)

- ▶ User selects:
 - ▶ ID_{MU} , PW_{MU}
 - ▶ Biometric B_{MU}
- ▶ Generate:
 - ▶ r (random number)
 - ▶ $(\sigma_{MU}, \tau_{MU}) = Gen(B_{MU})$

- ▶ Compute:

$$W = H(PW_{MU} || r || ID_{MU} || \sigma_{MU})$$

- ▶ Send $\langle ID_{MU}, W \rangle$ to LS

Registration Phase (Registration Server (LS) Side)

- ▶ Generate random u
- ▶ Compute:

$$K_{MU} = H(ID_{MU} || u || X)$$

$$Y_{MU} = K_{MU} \oplus W$$

- ▶ Encrypt identity:

$$DID_{MU} = Enc_X(ID_{MU} || u)$$

- ▶ Send $\langle Y_{MU}, DID_{MU} \rangle$

Summary of Registration Phase

Mobile user (MU)	Secure channel	Registration server (LS)
Selects r, ID_{MU} and PW_{MU}. Imprints B_{MU} and computes $W = H(PW_{MU} r ID_{MU} \sigma_{MU})$.	$\langle ID_{MU}, W \rangle$	Verifies ID_{MU}. If verification holds, computes $K_{MU} = H(ID_{MU} u X)$, $Y_{MU} = K_{MU} \oplus W$,
Stores Y_{MU}, DID_{MU} in the device. Computes $r^* = r \oplus H(\sigma_{MU} ID_{MU})$, $Z_{MU} = H(PW_{MU} r \sigma_{MU})$. Stores r^*, Z_{MU}, τ_{MU}, t in the device.	$\langle Y_{MU}, DID_{MU} \rangle$	$DID_{MU} = \text{Sym.Enc}_X(ID_{MU} u)$.

Package Phase

- ▶ PS generates content key:

$$KEY_{ID_{DC}}$$

- ▶ Encrypt content:

$$E(DC) = Sym.Enc_{KEY_{ID_{DC}}}(DC)$$

- ▶ Sends:

- ▶ Encrypted content to CS
- ▶ Key seed to LS

- ▶ Upon receiving the packaged content, the CS uploads the packaged content on the media server and displays the content information on the website.
- ▶ Upon receiving the key seed, the LS securely stores the content key and provides the content key to the authorized users.

Content Key Acquisition Phase

- ▶ Step C1. MU inputs his/her identity ID_{MU} and password PW_{MU} in the mobile device. After that MU imprints the biometrics B_{MU}^* at the sensor of the mobile device.
 - ▶ Step C1.1. The DRM-AP computes $\sigma_{MU}^* = Rep(B_{MU}^*, \tau_{MU})$.
 - ▶ Step C1.2. The DRM-AP further computes $r' = r^* \oplus H(\sigma_{MU}^* || ID_{MU})$, and then $Z_{MU}^* = H(PW_{MU} || r' || \sigma_{MU}^*)$.
 - ▶ Step C1.3. The DRM-AP checks the condition $Z_{MU}^* = Z_{MU}$. If it does not hold, the password and biometrics verification fails, and the session is terminated immediately.
 - ▶ Step C1.4. The DRM-AP computes $W^* = H(PW_{MU} || r^* || ID_{MU} || \sigma_{MU}^*)$, and then $K_{MU}^* = Y_{MU} \oplus W^*$.
 - ▶ Step C1.5. The DRM-AP computes $DID_{DC} = ID_{DC} \oplus H(K_{MU}^* || T_{MU} || ID_{MU})$ for the selected digital content DC , which the user MU wants to access, where T_{MU} is the current timestamp used by DRM-AP.
 - ▶ Step C1.6. The DRM-AP also computes $C_1 = H(ID_{MU} || ID_{DC} || T_{MU} || K_{MU}^*)$.
 - ▶ Step C1.7. The MU sends the login message $\langle DID_{MU}, DID_{DC}, C_1, T_{MU} \rangle$ to LS via a public channel.

Content Key Acquisition Phase

- ▶ Step C2. Upon receiving the message $\langle DID_{MU}, DID_{DC}, C_1, T_{MU} \rangle$ at time T'_{MU} , LS does the following:
 - ▶ Step C2.1. LS verifies the time delay in message transmission by checking the condition $|T'_{MU} - T_{MU}| < \Delta T$, where ΔT represents the maximum transmission delay or preset acceptable delay threshold. If it is valid, LS retrieves the user identity ID_{MU} and u as $(ID_{MU} || u) = \text{Sym.Dec}_X(DID_{MU})$.
 - ▶ Step C2.2. Then, LS computes $K_{MU} = H(ID_{MU} || u || X)$ and also retrieves ID_{DC} from DID_{DC} as $ID_{DC} = DID_{DC} \oplus H(K_{MU} || T_{MU} || ID_{MU})$.
 - ▶ Step C2.3. LS verifies the condition $C_1 = H(ID_{MU} || ID_{DC} || T_{MU} || K_{MU})$. If the verification succeeds, LS computes $C_2 = KEY_{ID_{DC}} \oplus H(ID_{MU} || K_{MU} || T_{LS} || T_{MU})$ and $C_3 = H(ID_{MU} || K_{MU} || T_{MU} || T_{LS} || KEY_{ID_{DC}})$.
 - ▶ Step C2.4. LS then sends the message $\langle C_2, C_3, T_{LS} \rangle$ to MU .

Content Key Acquisition Phase

- ▶ Step C3. Upon receiving the message $\langle C_2, C_3, T_{LS} \rangle$ at time T'_{LS} , MU does the following:
 - ▶ Step C3.1. MU verifies the time delay in message transmission by checking the condition $|T'_{LS} - T_{LS}| < \Delta T$. If the time delay in message transmission is valid, MU continues to compute $KEY'_{ID_{DC}} = C_2 \oplus H(ID_{MU} || K_{MU} || T_{LS} || T_{MU})$.
 - ▶ Step C3.2. MU then verifies the condition $C_3 = H(ID_{MU} || K_{MU} || T_{MU} || T_{LS} || KEY'_{ID_{DC}})$. If the verification fails, the session is terminated. Otherwise, the content key is authenticated.
 - ▶ Step C3.3. MU can use the content key $KEY'_{ID_{DC}}$ to access the encrypted digital content $E(DC)$ in future.

Summary of Content Key Acquisition Phase

Mobile user (MU)	Public channel	License server (LS)
Inputs ID_{MU} and PW_{MU}. Imprints B_{MU}^*. Computes $\sigma_{MU}^* = Rep(B_{MU}^*, \tau_{MU})$, $r' = r^* \oplus H(\sigma_{MU}^* ID_{MU})$, $Z_{MU}^* = H(PW_{MU} r' \sigma_{MU}^*)$. Verifies $Z_{MU}^* = Z_{MU}$, computes $W^* = H(PW_{MU} r^* ID_{MU} \sigma_{MU}^*)$, $K_{MU}^* = Y_{MU} \oplus W^*$, $D = H(K_{MU}^* T_{MU} ID_{MU})$, $DID_{DC} = ID_{DC} \oplus D$, $C_1 = H(ID_{MU} ID_{DC} T_{MU} K_{MU}^*)$.	$\langle DID_{MU}, DID_{DC}, C_1, T_{MU} \rangle$	Verifies $T'_{MU} - T_{MU} < \Delta T$. Computes $K_{MU} = H(ID_{MU} u X)$, $D = H(K_{MU} T_{MU} ID_{DC})$, $ID_{DC} = DID_{DC} \oplus D$. Verifies if $C_1 = H(ID_{MU} ID_{DC} T_{MU} K_{MU})$? Computes $C_2 = KEY_{ID_{DC}} \oplus H(ID_{MU} K_{MU} T_{LS} T_{MU})$, $C_3 = H(ID_{MU} K_{MU} T_{MU} T_{LS} KEY_{ID_{DC}})$.
Verifies $T'_{LS} - T_{LS} < \Delta T$. Computes $KEY'_{ID_{DC}} = C_2 \oplus H(ID_{MU} K_{MU} T_{LS} T_{MU})$. Verifies if $C_3 = H(ID_{MU} K_{MU} T_{MU} T_{LS} KEY'_{ID_{DC}})$? Stores $KEY'_{ID_{DC}}$.	$\langle C_2, C_3, T_{LS} \rangle$	Stores $KEY_{ID_{DC}}$.

Password & Biometric Update

Mobile user (MU)	DRM-AP
Inputs ID_{MU} and PW_{MU}^{old} . Imprints B_{MU}^{old} .	Computes $\sigma_{MU}^{old} = Rep(B_{MU}^{old}, \tau_{MU})$, $r^{old} = r^* \oplus H(\sigma_{MU}^{old} ID_{MU})$, $Z_{MU}^{old} = H(PW_{MU}^{old} r^{old} \sigma_{MU}^{old})$. Verifies if $Z_{MU}^{old} = Z_{MU}$? Computes $W^{old} = h(PW_{MU}^{old} r^{old} ID_{MU} \sigma_{MU}^{old})$, $K_{MU}^{old} = Y_{MU} \oplus W^{old}$.
Inputs PW_{MU}^{new} , B_{MU}^{new} .	Computes $Gen(B_{MU}^{new}) = (\sigma_{MU}^{new}, \tau_{MU}^{new})$, $W^{new} = H(PW_{MU}^{new} r^{new} ID_{MU} \sigma_{MU}^{new})$, $Y_{MU}^{new} = K_{MU}^{old} \oplus W^{new}$, $r^{**} = r^{new} \oplus H(\sigma_{MU}^{new} ID_{MU})$, $Z_{MU}^{new} = H(PW_{MU}^{new} r^{new} \sigma_{MU}^{new})$. Replaces Y_{MU}, Z_{MU}, r^* and τ_{MU} with Y_{MU}^{new}, Z_{MU}^{new}, r^{**} and τ_{MU}^{new}, respectively.

Security Features

- ▶ User Anonymity
- ▶ Mutual Authentication
- ▶ Key Agreement
- ▶ Resistance to:
 - ▶ Replay Attack
 - ▶ Password Guessing Attack
 - ▶ Stolen Device Attack
 - ▶ Stolen Verifier Attack

User Anonymity

- ▶ Identity hidden as:

$$DID_{MU} = Enc_X(ID_{MU} || u)$$

- ▶ Adversary cannot retrieve ID_{MU}

Replay Attack Resistance

- ▶ Uses timestamps:

$$|T' - T| < \Delta T$$

- ▶ Prevents reuse of messages

Mutual Authentication

- ▶ Verified using:

$$C1 = H(...)$$

$$C3 = H(...)$$

- ▶ Both user and server authenticate each other

Conclusion

- ▶ Secure DRM system for mobile environment
- ▶ Uses biometrics + password + anonymity
- ▶ Efficient and robust
- ▶ Provides strong security guarantees

Thank You

Questions?